WHY AUTHENTICATION SEEMS LIKE A ONE-WAY STREET

Many people assume that only users authenticate to systems, but authentication is a two-way street. After all, if we're trying to preserve relationship integrity, the authenticity of both parties to the relationship matters. Put more simply: when you log into a website, how do you know it's the real site and not an attacker impersonating it? This is where *cryptographic authentication* comes in.

Transport Layer Security (TLS) is the protocol that places the little lock in the address bar of your browser. Websites and applications authenticate themselves using TLS, which relies on certificates issued by trusted Certificate Authorities (CAs). The certificate, which can be freely shared, cryptographically links the domain name of the server to the public key used to authenticate the session. The public key allows the browser and server to create a confidential communications channel. Your browser verifies these certificates to ensure you're connecting to the legitimate server and shows you the little lock. Clicking on the lock can give you the details of why the site is trusted.

Like anything, TLS has its weaknesses. TLS can be undermined by misconfigured certificates, expired CAs, or advanced attacks like man-in-the-middle (MITM) attacks, where a hacker is able to overcome the certificate's cryptographic protections to intercept traffic. Moreover, the lock usually only shows that the key belongs to the domain name, but people click on the wrong domain name all the time—that's the basis of phishing attacks. For example, the name `twitter.com.info` could have a certificate and show a browser lock. If you're in a hurry or don't understand URLs, you might ignore the `.info` and assume the site is legitimate.

For people, authentication often feels like a one-way process because system authentication is handled silently by browsers and applications. But authenticating the system is important too. If you can't trust that you're talking to the right system, you may unknowingly authenticate to an attacker, leading to phishing, credential theft, or session hijacking.